CCNA（200-301 v1.1）　5.0 セキュリティの基礎　#20

セキュリティの基本と AAA

出題範囲 5.1・5.2・5.4・5.8 ― 脅威・脆弱性・エクスプロイトと対策、人と場所を守る仕組み、パスワードとその代わり、AAA と 802.1X

各ページの下に、根拠にしたCiscoの資料・RFC・NISTの文書を書いた（青い文字を押すと開く）

全体像 5.1 Define key security concepts／5.2 Describe security program elements／5.4 Describe security password policy elements／5.8 Compare authentication, authorization, and accounting concepts

1 脅威と攻撃（5.1）
脅威・脆弱性・エクスプロイト・リスク・対策、DoS・なりすまし・中間者・マルウェア・フィッシング

2 セキュリティプログラム（5.2）
意識向上・トレーニング・物理アクセス制御

3 パスワードとその代わり（5.4）
NIST SP 800-63B-4 の決まり、MFA、証明書、生体認証

4 AAA（5.8）
認証・認可・アカウンティング、TACACS+ と RADIUS、802.1X

CCNAでの問われ方	
Define・Describe・Compare	言葉の**定義と違い**。「脆弱性と脅威の違い」「ワームとウイルス」「MFA になる組み合わせ」「認可はどれ」「802.1X でスイッチの役は」

芯：穴（脆弱性）を、だれか（脅威）が、道具（エクスプロイト）で突く。防ぐのは技術だけでなく**人（教育）と場所（物理）**も。入口では「**だれ？・何をしてよい？・何をした？**」を分けて管理する（AAA）。

関連 パスワード・SSH・TACACS+／RADIUS の設定は #11、DHCP スヌーピング・DAI・ポートセキュリティは #23

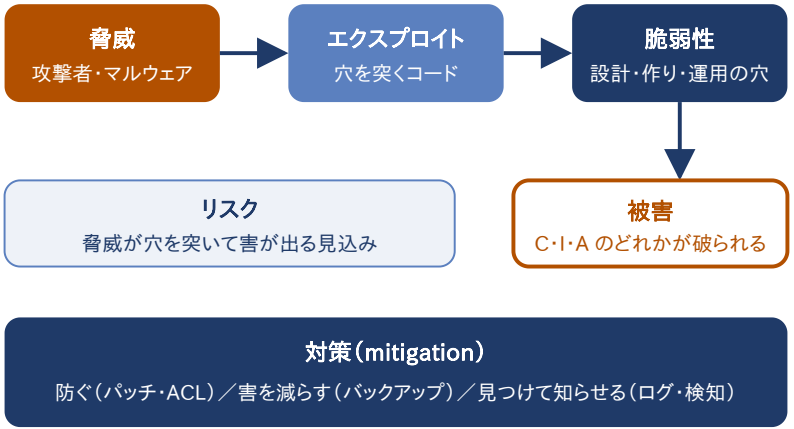
出典：Cisco CCNA Exam v1.1 (200-301) Exam Topics（5.1・5.2・5.4・5.8）

第1章

脅威と攻撃

言葉の関係をおさえ、ネットワーク・ソフト・人をねらう攻撃を見分ける。

脅威・脆弱性・エクスプロイト・リスク・対策



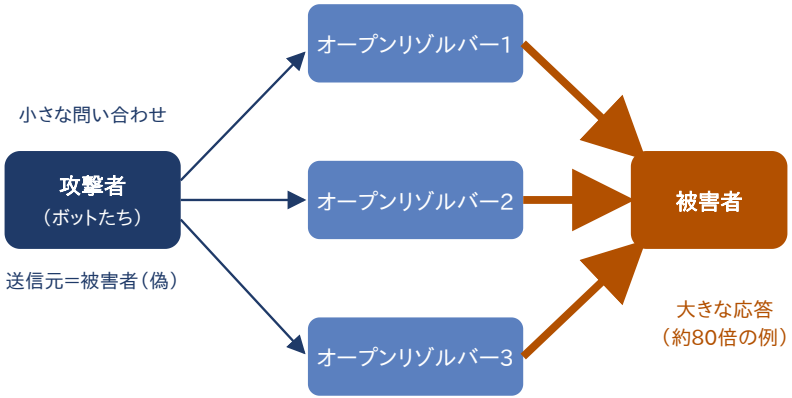
図は RFC 4949 の定義から Claude が作った

CIA の3要素（守るもの）		
要素	意味	破る攻撃の例
機密性 C	許された人だけが見られる	盗み見・中間者
完全性 I	勝手に変えられていない	改ざん・中間者
可用性 A	使いたいときに使える	DoS・ランサムウェア

ゼロデイ：ベンダーがまだ知らない（パッチのない）穴を突く攻撃。パッチだけでは防げないので、不審な動きの検知と組み合わせる。

出典：RFC 4949（threat・vulnerability・risk・countermeasure・data confidentiality・data integrity・availability）／Cisco「What Is an Exploit?」（An exploit is not malware itself／zero-day exploits）／Cisco「What Is a Cyberattack?」（CIA Triad）／NIST CSRC Glossary「zero day attack」

使えなくする：DoS・DDoS とリフレクション・増幅



攻撃	しくみ
DoS	正規の利用をできなくする・遅らせる。例：**SYN フラッド**（偽の送信元から SYN を大量に送り、返事待ちで埋める）
DDoS	**たくさんの機器**（乗っ取られたボット）から一斉に
リフレクション・増幅	送信元を**被害者に偽り**、第三者のサーバーに問い合わせて、**大きな応答**を被害者へ

根本の対策：送信元を偽ったパケットを自分のネットワークから出さない**入口フィルタリング**（BCP 38／RFC 2827）。DNS は外の人に再帰の問い合わせを許さない。

出典：RFC 5358（reflector attacks … small query-large response … amplification factor … could be around 80／the only real solution: … ingress filtering）／RFC 2827／RFC 4949（denial of service・SYN flood・distributed attack・zombie）／Cisco「What Is a DDoS Attack?」（botnets）。図はClaudeが作った例

偽る・割り込む・調べる・突く・当てる

攻撃	何をする	主な対策
スプーフィング	送信元の IP・MAC などを**偽って**なりすます。ほかの攻撃の土台	入口フィルタリング、DHCP スヌーピング・DAI（#23）
中間者攻撃（MITM）	2者の**間に割り込み**、盗み見・書き換え。LAN ではうその ARP でルーターになりすます方法がある	暗号化と相手の認証（証明書）、DAI
偵察	攻撃の**前に**、機器・ソフトの版・開いたポート・人の情報を集める	不要なサービスを止める、出す情報を減らす
バッファオーバーフロー	書き込みの範囲を確かめない不具合を突き、長いデータで動きを乗っ取る・止める	パッチ（修正）
パスワード攻撃	**辞書攻撃**（一覧を順に試す）・**総当たり**・ほかで漏れた組を試す（クレデンシャルスタッフィング）	長いパスワード、失敗回数の制限、MFA

見分け方：「間に入る」なら中間者、「偽の送信元」ならスプーフィング、「攻撃の前の下調べ」なら偵察、「一覧を試す」なら辞書攻撃。

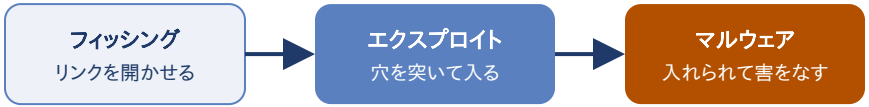
出典：RFC 4949（masquerade／spoof・man-in-the-middle attack・buffer overflow・dictionary attack・brute force）／Cisco「What Is a Cyberattack?」（Reconnaissance・Brute force attacks・credential stuffing）／Cisco Guide to Harden Cisco IOS Devices（ARP poisoning … man-in-the-middle）

マルウェアの見分け方

種類	単独で動く	自分で増える
ウイルス	×（宿主が要る）	○（ほかのファイルへ）
ワーム	○	○（ネットワークで）
トロイの木馬	○（役に立つふり）	×

ほかに出てくる名前	
ランサムウェア	データを暗号化して使えなくし、お金を要求
スパイウェア	こっそり情報を集めて送る（キーロガーなど）

エクスプロイトとマルウェアの関係



例：メール → ブラウザーの穴を突く → ランサムウェアが動く

ひっかけ：「トロイの木馬は自分で増える」は誤り。「ウイルスは単独で動ける」も誤り（宿主のプログラムが実行されて動く）。

出典：RFC 4949（virus：A virus cannot run by itself; it requires that its host program be run／worm：can run independently, can propagate … onto other hosts／Trojan horse）／Cisco「What Is Malware?」（Trojan viruses are not designed to self-replicate／Ransomware … Spyware）／Cisco「What Is an Exploit?」（a method used by cybercriminals to deliver malware）。
流れの例はClaudeが作った

人をねらう：ソーシャルエンジニアリング

手口	中身
フィッシング	本物らしいメール・メッセージで、入力させる・入れさせる。**多くの人に**ばらまく
スピアフィッシング	**特定の人・部署**にねらいを絞る
ホエーリング	**経営者**など地位の高い人をねらう
ビッシング／スミッシング	**電話の声**／**SMS** で行う
プリテキスティング	口実（「銀行の者です」など）を作ってなりすます
テールゲーティング	許された人のあとについて**建物に入る**（物理）

対策の組み合わせ

教育
意識向上と、模擬フィッシングなどの訓練

決まり（ポリシー）
パスワードを人に教えない、来訪者はエスコート、など

技術
メールのフィルター、盗まれても入られない MFA

> 技術の穴ではなく**人の心理**（信頼・好奇心・あせり）をつくので、技術だけでは防げない。

出典：Cisco「What Is Phishing?」（spear phishing／vishing・SMiShing／Security awareness training／A strong MFA solution）／Cisco「What Is Social Engineering?」（whaling／awareness training／security policies／physical security controls such as visitor logs, escort requirements）／NIST SP 800-53 Rev. 5 AT-2(3)（phishing, pretexting, … tailgating）

第2章

セキュリティプログラム

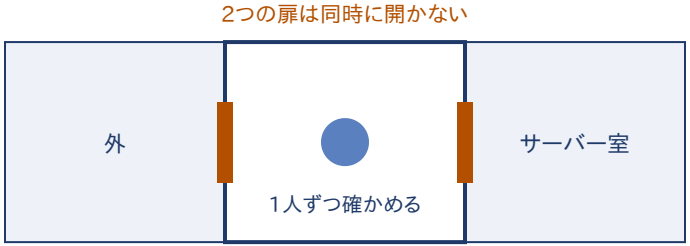
人に知らせ、役割ごとに鍛え、場所への出入りを限る。

意識向上・トレーニング・物理アクセス制御

要素	だれに・何を	例
意識向上	**全員**に。注意を向けさせる。受け手は聞く側	ポスター、ログイン画面の注意、お知らせメール
トレーニング	**役割ごと**に。仕事に要る知識と技能	管理者向けの講習、**予告なしの模擬フィッシング**
物理アクセス制御	建物・部屋・機器に**入れる人を限り記録**	カードリーダー、鍵、生体認証の読み取り機、入退室の記録、来訪者のエスコート

なぜ物理か：機器に直接さわれれば、コンソールからパスワードリカバリーができてしまう（#11）。ネットワークの設定だけでは守れない。

アクセス制御の前室（マントラップ）



あとについて入る（テールゲーティング）を防ぐ

出典：NIST SP 800-53 Rev. 5 AT-2（Awareness techniques include displaying posters, … logon screen messages）・AT-2(1)（no-notice social engineering attempts）・AT-3（Role-based Training）・PE-3（Physical access devices include keys, locks, combinations, biometric readers, and card readers／Escort visitors）・PE-3(8)（access control vestibule … also known as piggybacking or tailgating）／NIST CSRC Glossary「awareness」（Awareness is not training）。図はClaudeが作った

第3章

パスワードとその代わり

長さとブロックリストで守り、パスワード以外の要素と組み合わせる。

パスワードの決まり：NIST SP 800-63B-4

項目	よくある古い決まり	NIST SP 800-63B-4
長さ	8文字以上	1要素だけで使うなら **15文字以上**（MFA の一部なら 8 以上）。**64文字以上**まで入れられる
組み合わせ	大文字・数字・記号を必ず	そうした決まりは**課さない**
定期変更	90日ごと	**求めない**。漏れた証拠があれば変えさせる
弱いもの	—	よく使われる・漏れたものの**ブロックリスト**で拒む
入力	貼り付け禁止	**パスワードマネージャー**・貼り付けを許す
失敗	—	失敗回数を**制限**する

なぜ組み合わせの決まりをやめたか

> 決まりを課すと、人は予想しやすい形で応じる（「password」→「Password1」）。強さはあまり増えず、使いにくくなるだけ。

機器では	
初期パスワード	最初に使う前に変える
保存	平文で残さない（enable secret など、#11）

出典：NIST SP 800-63B-4 3.1.1.2（minimum of 15 characters … minimum of eight characters／maximum password length of at least 64／SHALL NOT impose other composition rules／SHALL NOT require subscribers to change passwords periodically／blocklist／password managers … paste／rate-limiting）・Appendix A（users respond in very predictable ways … "Password1"）／NIST SP 800-53 Rev. 5 IA-5（Changing default authenticators prior to first use）

多要素認証（MFA）：違う種類を2つ以上

知っているもの
something you know
パスワード・PIN

持っているもの
something you have
スマホのアプリ（OTP）・トークン・スマートカード

本人の特徴
something you are
指紋・顔・虹彩（生体認証）

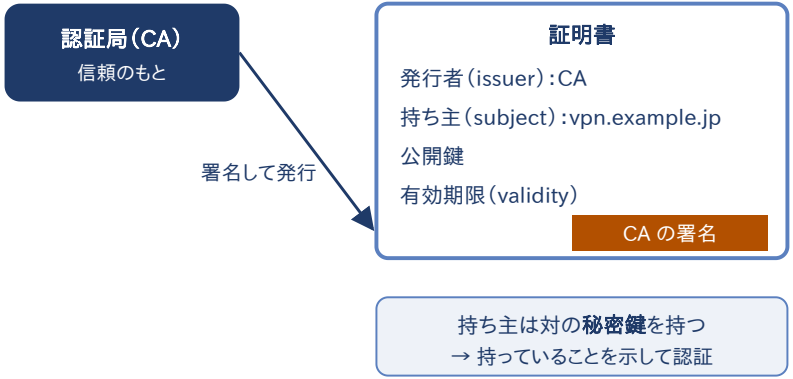
この3種類のうち、**違う種類を2つ以上**組み合わせると MFA

組み合わせ	MFA?	理由
パスワード+スマホに出る6桁の数字	○	知っている+持っている
スマートカード+PIN	○	持っている+知っている
パスワード+秘密の質問	×	どちらも知っているもの
パスワードを2回	×	同じ要素の繰り返し

出典：NIST SP 800-53 Rev. 5 IA-2(1)（two or more different factors … something you know …, something you have …, or something you are）／NIST CSRC Glossary「multi-factor authentication」（CNSSI 4009-2022）／NIST SP 800-63B-4 3.1.4（Single-factor OTP … as few as six decimal digits）。表の例はClaudeが作った

証明書と生体認証

証明書（X.509）のしくみ



	証明書	生体認証
要素	持っているもの（秘密鍵の入った機器）	本人の特徴
よさ	パスワードを送らない	覚えなくてよい
気をつけること	秘密鍵を守る、期限と失効	確率で判定（誤って合う・合わない）、**漏れても取り替えにくい**

NIST：生体認証は**単独の認証手段とは認めない**。持っているもの（機器）と組み合わせた MFA の一部としてだけ使い、生体以外の方法も用意する。

出典：RFC 4949（public-key certificate：binds a system entity's identifier to a public key value … digitally signed・certification authority）／RFC 5280 4.1（issuer・validity・subject・subjectPublicKeyInfo）／NIST SP 800-63B-4 3.2.3（Biometrics SHALL only be used as part of multi-factor authentication with a physical authenticator … An alternative non-biometric authentication option SHALL always be provided／Biometric comparison is probabilistic）。図はClaudeが作った例

第4章

AAA と 802.1X

だれ？・何をしてよい？・何をした？ を分けて考え、ポートでも利用者を確かめる。

AAA：認証・認可・アカウンティングを比べる

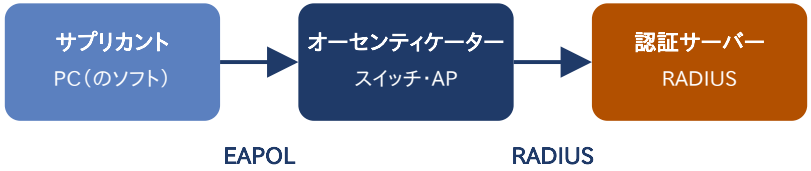


ローカルとサーバー		
	ローカル	サーバー（TACACS+・RADIUS）
ユーザー	機器ごとに username	**一か所**にまとめる
記録	機器ごとにばらばら	サーバーに集まる
サーバー停止	影響なし	最後に `local` を置いて備える

TACACS+ と RADIUS（詳しくは #11）		
	TACACS+	RADIUS
運ぶ	TCP 49	UDP 1812・1813
暗号化	中身全部	パスワードだけ
認証と認可	**分ける**	いっしょ
向く用途	管理者のログイン	利用者の接続（802.1X）

出典：Security CG IOS XE 17.9（Catalyst 9300）「Configuring TACACS+」（centralized validation of users／Authorization … what commands a user can execute／Accounting … billing, auditing … user identities, start and stop times, executed commands）／Cisco「TACACS+ and RADIUS Comparison」／RFC 8907・RFC 2865

802.1X：ポートにつないだ人を、使わせる前に確かめる



スイッチは自分で判断せず EAP を**中継**する

認証前：EAPOL・CDP・STP だけ → 認証後：ふつうの通信

注意 Catalyst 9300 では TACACS+ は 802.1X に使えない。802.1X は初期では無効

```
aaa new-model
aaa authentication dot1x default group radius
dot1x system-auth-control       ! 全体で有効
radius server RAD1
 address ipv4 10.0.1.12
 key Rad1Key
interface g1/0/2
 switchport mode access
 authentication port-control auto
 dot1x pae authenticator
```

EAP	いろいろな認証方法（パスワード・証明書）を載せる**入れ物**
EAPOL	EAP を LAN のフレームで運ぶ形
port-control auto	最初は unauthorized、認証が済むと authorized

出典：Security CG IOS XE 17.9「Configuring IEEE 802.1x Port-Based Authentication」（TACACS is not supported with 802.1x authentication／allows only EAPOL, CDP, and STP traffic／the switch begins its role as the intermediary, passing EAP frames／Switch 802.1x enable state: Disabled／設定の手順）／RFC 3748 1.2（authenticator・Supplicant・backend authentication server）。設定はCiscoの例の書式でClaudeが作った例

よくあるひっかけ

よくある思い込み	正しくは
脆弱性と脅威は同じ	脆弱性は**穴**、脅威は**害を与えうるもの**、エクスプロイトは**穴を突く道具**
エクスプロイトはマルウェアの一種	Cisco の説明では、マルウェアを**送り込む方法**でマルウェアそのものではない
トロイの木馬は自分で増える	増えない。自分で広がるのは**ワーム**
フィッシングはメールだけ	電話（ビッシング）・SMS（スミッシング）もある
パスワード＋秘密の質問は MFA	どちらも知っているもの。**違う種類**が要る
パスワードは記号を混ぜ、定期的に変えるのが NIST の決まり	SP 800-63B-4 は**どちらも求めない**。長さ・ブロックリスト・失敗回数の制限
意識向上とトレーニングは同じ	意識向上は**全員に注意**、トレーニングは**役割ごとの技能**
認可は「本人か確かめる」	それは**認証**。認可は「何をしてよい」
802.1X でスイッチが合否を決める	決めるのは**認証サーバー**（RADIUS）。スイッチは中継

出典：このPDFの各ページの資料

まとめ

脅威と攻撃
脆弱性（穴）・脅威・エクスプロイト・リスク・対策、CIA。DoS／DDoS／増幅・スプーフィング・中間者・偵察・パスワード攻撃・マルウェア・フィッシング

セキュリティプログラム
意識向上（全員）・トレーニング（役割ごと・模擬訓練）・物理アクセス制御（カード・記録・前室）

パスワードとその代わり
長さ・ブロックリスト・組み合わせの決まりと定期変更は求めない。MFA＝違う種類2つ以上、証明書、生体認証は MFA の一部

AAA と 802.1X
だれ？・何をしてよい？・何をした？。サプリカント・オーセンティケーター・RADIUS、EAPOL

設定のまとめ

```
aaa new-model
aaa authentication login default group tacacs+ local
aaa authentication dot1x default group radius
dot1x system-auth-control
interface g1/0/2
 authentication port-control auto
 dot1x pae authenticator
```

確かめる: `show dot1x`・`show authentication sessions`

次の分野: #21 VPN で、IPsec のサイト間 VPN とリモートアクセス VPN を読む。

出典：このPDFの各ページの資料